加密协议

- 加密
  - L7
    - HTTPS | SSH | SFTP | SCP | SET
    - 信令协议signal：用于Skype, Whatsapp端到端加密语音/视频/即时消息 (2013 旧称TextSecure)
      - 加密算法：X3DH交换 + RSA256 + SHA256
  - L5
    - SRPC
  - L4.5
    - 安全套接层SSL (旧 by NetScape)
      - v1.0 未公开 - v2.0 (1990 - 1995)
        - v3.0：协议嵌入浏览器, 加密TCP by RC4 40/128位 (1996)
    - 传输层安全TLS
      - v1.0：SSLv3.0微差版 (1999 旧)
        - v1.1：防CBC加密攻击 (2006 旧)
          - POODLE降级攻击：TLS1.0/SSL3.0 (降级加密密文填塞 Padding Oracle On Downgraded Leg... 2014)
            - 黑客截获流量 - 篡改密码块 - 新协议握手失败 > 回退旧协议
            - 防：浏览器+服务器禁用SSL/TLS1.0旧协议
      - v1.2：+AES、SHA256、PRF (2008)
        - *(完美)前向保密PFS：主密钥泄露 不会导致 历史会话K泄露 ((perfect) forward secrecy)
          - 洋葱路由Tor：匿名路由流量 by 加密+PFS + >3重置节点 (部分国家非法)
        - 协议：alert、handshake、application_data、change_cipher_spec
          - 终端发送
            - ChangeCipherSpec：通知切换加密套件状态，即开启密文传输
            - Client Finished：终端握手结束通知 + 生成并加密发送 所有握手消息的HMAC
              - 服务器：匹配HMAC - 证明握手结束
          - 服务器响应
            - ChangeCipherSpec：通知已切换
            - Server Finished：服务器握手结束通知 + 生成并加密发送 所有握手消息的HMAC
              - 终端：匹配HMAC - 证明握手结束
        - 劣
          - RSA算法不支持前向加密 》Heartbleed攻击
          - 压缩 》CRIME旁道攻击：压缩率使信息容易泄露 (Compression Ratio Info-leak Made Easy)
            - 正常：浏览器发送密文 - Web服务器响应 -经HTTP压缩- 浏览器解压缩
            - 黑客：控制输入(如SK) - 浏览器发送n次密文 - 观察响应压缩大小 - 倒推SK
            - 防：服务器/浏览器禁用HTTP压缩、TLS1.3已禁用压缩
      - v1.3：+Extension提升兼容性、-不安全算法(RSA>ECDHE, MAC>AEAD, PRF>HKDF...)、-去数据压缩、-KeyExchange消息、+Cert Verify消息、-SessionID恢复会话 (2018 不向后兼容)
      - 协议 v1.3
        - Record Layer (记录层)
          - Application Data - Fragmentation - TLSInnerPlainText Padding - TLSCipherText - TLSCipherText+Header
            应用数据 数据分块 数据填充 v1.3 加密+完整性viaAEAD
          - 数据包
            - 1.握手 - IP头 | TCP头 | RL头+HP头 | 数据
            - 2.传数 - IP头 | TCP头 | RL头+AD头 | 数据
        - Handshake (握手协议HP)
          - Client报文
            - Client Hello：我想用哪些协议版本、哪些密钥套件 + Extension
              - TSL1.3 Record Layer: Handshake protocol: Client Hello
                Handshake Type: Client Hello
                Version: TLS 1.2 (实为1.3 兼容性显示)
                Random: ... (Client生成用于生成KEY)
                Session ID: ... (首次连接:无, 再次无需握手-基于ID恢复会话)
                Cipher Suites (如13 suites)
                Extention:
                supported_versions: TLS 1.3
                signature_algorithms: (Client支持的哈希算法, 签名算法)
                supported_groups: 如x25519, secp256r1... (Client支持哪些ECDHE密钥交换算法)
                key_share: 如ecc123456... (Client ECDHE密钥参数*32位)
          - Server报文
            - Server Hello：我选择哪个密钥套件 + Extension
              - TSL1.3 Record Layer: Handshake protocol: Server Hello
                Handshake Type: Server Hello
                Version: TLS 1.2
                Random: Server生成用于生成KEY
                Session ID: ...
                Cipher Suite: 如TLS_AES_128_GCM_SHA256
                Extention:
                supported versions: TLS 1.3
                key_share: 如98765... (Server ECDHE密钥参数*32位)
            - Encrypted Extensions
              - TSL1.3 Record Layer: Handshake protocol: Encrypted Extensions E[supported_groups: x25519]
            - Certificate：如 [淘宝]数字证书
              - TSL1.3 Record Layer: Handshake protocol: Certificate
                Opaque Type: Application Data
                Version: TLS 1.x
                Handshake protocol: Certificate
            - Certificate Verify：[淘宝]私钥签名SeverHello消息
              - TSL1.3 Record Layer: Handshake protocol: Certificate Verify
            - Certificate Request(可选)：如 请求[客户端]数字证书 (如网银-证书存于银行U盾)
            - Finished
              - TSL1.3 Record Layer: Handshake protocol: Server Hello
          - Client报文
            - Certificate(可选)：如 [客户端]数字证书
            - Certificate Verify(可选)：对以上消息的HMAC作数字签名
              - 终端：验证[淘宝]证书 + 提取[淘宝]公钥
            - Finished
            - HTTP Request：GET /
          - Server报文
            - HTTP Response：OK，DATA
          - 握手协议
            - 第2阶段
              - 服务器发送：密钥交换、证书签名
                - 第1阶段密钥交换算法
                  - **DH > Server Key Exchange：生成参数Server Params - 发送**
                  - **RSA > 跳至Client Key Exchange**
                - ServerHello Done
            - 第3阶段
              - 客户端发送：密钥交换、Finished
                - **Client Key Exchange**
                  - **DH：生成参数Client Params - 发送**
                    - **终端 & 服务器：基于2个DH参数 生成预主密钥pre_master_secret(随机数)**
                  - **RSA：生成预主密钥pre_master_secret(随机数) - [淘宝]公钥加密发送**
              - 终端 & 服务器：分别
                - **生成pre_master_secret - 生成MS by HKDF函数**
                - 响应ChangeCipherSpec
                  - Finished
              - **终端 & 服务器：生成MasterSecret by 伪随机函数PRF(3个随机数)**
                - **终端：再生成client_write_key = PRF(MS) - 用于加密AD**
                - **服务器：再生成server_write_key = PRF(MS) - 用于加密AD**
        - Applicate Data (应用数据)
          - 第5阶段：浏览器与服务器会话 - 传输数据
        - Alert (告警)
          - 第6阶段：浏览器请求Close notify
            - error | exception conditions-如错误密钥 | notification-如会话终止
        - Heartbeat
      - SSL检查工具：流量被加密 > 无法监控 - 介入通信 by "MitM攻击" - 流量明文=可检测
    - 用户数据报DatagramTLS
      - 演化：TLS基于TCP无法支持语音流量 》基于UDP(端口443)的TLS
        - 应用：加密SIP
  - L3
    - IPSec
    - 软件IP加密swIPe：1993、实验性未推广
  - L2
    - MACSec：Cisco开发-交换机间加解密
      - 演化：仅用IPSec=流量全加密》内网难以流量分析
  - L1
    - 加密机：政府-两端部署
      - 如高保障互联网协议加密机HAIPE：基于IPSec
- 认证 (L2)
  - 网络访问控制NAC：一种"端到端"的安全结构
    - 作用
      - 访问控制：RBAC
      - 状态/健康检查：验证接入设备安全 by 内置代理/外部扫描，如杀毒软件/补丁/FW (posture assessment = risk-based AC)
    - NAC类型
      - 基于代理
        - pre-admin：入网前检查
        - 监控代理 部署在每台设备 - 定期扫描配置文件 - 异常则自动隔离至子网/VLAN修复 + 定期下载/更新配置文件
        - 类型
          - 可解：设备访问门户网站时- 自动下载执行 - 完成后下架，基于Web/移动代码编程
          - 永久：作为软件安装在设备上
      - 无代理/网络监控
        - post-admission：基于用户入网后活动允许/拒绝访问、带内/带外监控、系统入网后才检查
        - NAC服务器 扫描端口,服务,漏洞 - 异常则手动解决
    - 部署
      - 带内：=决策 + 执行 节点
      - 带外：=决策 节点、交换机/WAP=执行 节点
  - 拓扑：Supplicant终端软件 -1- Authenticator(网络访问服务器NAS-交换机/WAP) -2- 身份验证服务器AS
    - 1. PPPoE, EAPoL(802.1x), Portal, WiFi、MAC
    - 2. AAA, EAPoverRADIUS(802.1x)
    - AS =
      - AAA服务器：配置格式和用户信息存于 本地DB、支持静态密码
      - AAA服务器 + AD/LDAP服务器：存于外部、支持动态+静态密码
  - AAA协议 (L7)
    - 演化：本地路由器防火墙分别创建用户列表=费事且无计费 》认证服务器统一认证 youtube, youku
    - 认证Authentication：身份 | 授权Authorization：角色权限 | 计费Accounting：操作记录
    - 类型
      - 远程认证拨号用户服务RADIUS (1980 UDP 老 1645(AA)+1646(A) 新 1812+1813)
        - 工业标准=适用所有厂商设备；推荐用于VPN/802.1x
        - 报文
          - Code | Identifier | Length | Authenticator | Attribute
            报文类型 | 匹配请求与响应报文 | 长度 | 验证响应报文+密码密文 | 属性三元组(AVP)=Type+Length+Value、2^8个
          - 1. NAS请求Access Request [用户名明文|密码密文] - 服务器响应Access-Accept [授权等级+ACL]
            - 2A捆绑《 信息在同一个报文；仅加密密码
          - 2. NAS请求Accounting Request START/STOP - 服务器响应
        - 劣：仅加密密码、不加密通信报文
        - 衍生 - RadSec：RADIUS over TCP+TLS = 加密通信 (2012 TCP 2083)
      - 终端访问控制器访问控制系统TACACS+ (1993 TCP 49)
        - 演化：TACACS(整合AuAu) 》XTACACS(分离AAA) 》TACACS+(支持MFA, 可改密码, 令牌重同步, UDP>TCP)
        - Cisco标准；推荐仅用于思科互联网操作系统IOS设备(面向网管)
          - 加密整个报文
        - 报文
          - version | type(哪个A) | seq_no | flag | session_id | length | Encrypted Request (报文密文)
            - 加密流程
              - 1. MD5_1 (session_id, key, version, seq_no)
              - 2. MD5_n (session_id, key, version, seq_no, MD5_n-1)
              - 3. pad = MD5_n + MD5_n-1 + ... MD5_1 - 长度=数据
              - 4. Encrypted Request = XOR (data, pad)
            - AVP比RADIUS多
          - 认证类型=ASCII
            - 1. 用户登录 - NAS请求Authentication_START [认证类型=ASCII] - 服务器响应Auth_REPLY [请求用户名] - NAS发送Auth_CONTIUNE [用户名] - 服务器响应Auth_REPLY [请求密码] - NAS发送Auth_CONTIUNE [密码] - 服务器响应Auth_REPLY_pass/fail
              - 允许动态密码
          - 认证类型=PAP/CHAP
            - 1. 用户登录 - NAS请求Auth_START [认证类型=PAP/CHAP|用户名|密码|MD5] - 服务器响应Auth_REPLY_pass/fail
          - 2. NAS请求Authorization_REQUEST_start exec - 服务器响应Auth_RESPONSE_pass/fail
            - 授权类型：权限控制 by
              - exec：telnet/terminal/SSH/FTP远程管理用户
              - command：用户执行的每条命令行
              - 接入用户：PPPoE/802.1x/Portal等NAC用户
          - 3. NAS请求Accounting_REQUEST for start/stop - 服务器响应Accounting_RESPONSE_record received
            - 计费类型
              - 连接计费：远程管理用户-登录退出
              - EXEC计费：远程管理用户--登录退出
              - 命令计费：执行命令时
              - 网络计费：PPPoE-上线下线
              - 系统计费：对网络进行故障诊断时
          - 3.5 NAS请求Authorization_REQUEST_command - 服务器响应Auth_RESPONSE_pass/fail
            NAS请求Accounting_REQUEST for command - 服务器响应Accounting_RESPONSE_record received
        - 优：报文全加密、AAA拆分、授权细至命令行、支持多协议-AppleTalk远程访问(ARA)协议/NetBIOS帧协议控制协议
      - Diameter(直径)协议 (1998 TCP/SCTP 3868)
        - 用于IMS/LTE网络
        - RADIUS(半径)升级版
          - +支持域内漫游(移动IP)、代理、VoIP
          - UDP > TCP/SCTP - 仅密码 > IPSec/TLS/EAP - AVP更多2^32个
          - C/S协议(RADIUS/TACACS+)：仅客户端可发起通信 》对等协议：服务器也可发起-主动要求身份验证
          - +Failover & Failback：主服务器故障时请求备用 & 恢复时切回
        - 组成
          - 基本协议：安全通信、版本协商
          - 扩展协议：身份验证
    - 应用
      - 登录识别：nas telnet/ssh/https
      - VPN拨入：nas pptp/l2tp/pppoe/ipsec
      - 穿越防火墙：nas auth-proxy(IOS) / cut-through(ASA)
  - MAC认证 - 无需客户端+WEP 适用哑终端、如IP电话/打印机 - 黑客可嗅探+伪装MAC
  - Captive Portal 门户认证：+Portal服务器
    - 终端欲连入 - 被重定向至门户页面 - 用户输入付款信息/登陆凭据 / 展示安全策略 - 用户同意后方可访问
    - 多用于公共WiFi，如星巴克、连后跳转网页输入登录信息 - 无需客户端+WEP
    - 优：无需用户名/密码
    - 劣：开放网络=不安全
  - PPPoE认证
    - = 基于以太网 而非专线的PPP、C/S架构=终端/NAS - 需客户端 适用计费场景、如ADSL
    - 报文
      - 以太帧：源MAC|目的MAC| 类型 |载荷(PPPoE帧)| FCS检错码
      - PPPoE帧：版本|类型 |Code|ID|Len| 载荷(PPP帧)
      - PPP帧 = Flag|广播地址|控制协议 |载荷| FCS |Flag - 载荷：Code|ID|Len|数据(三元组) - 三元组-类型：IP数据报/LCP协商报文...
    - 流程
      - 发现阶段
        - 1. C广播PADI(PPPoE Active Discovery Initial)报文 - S单播PADOffer报文 - 获知双方的MAC地址
        - 2. C单播PADRequest报文 - S单播PADSession-confirmation报文 - 分配唯一会话ID
      - 会话阶段
        - 3. LCP协商
          - 3.1 链路控制协议LCP
            - S接口配置#Encapsulation PPP, LCP open
            - C/S互发Config-Request报文 - 互回Config-ACK报文 - 建立L2连接、协商认证方式、检测链路质量
          - 3.2 认证协议AP
            - S接口配置#username password | #ppp authentication(pap/chap)
            - 密码验证协议PAP (简单快速 > 常用)
              - 二次握手：用户名+密码明文
              - C发Authenticate-Request报文 - S匹配本地用户表+回Au-Ack报文
            - Shiva(SPAP)：Win XP连Shiva LANRover时验证 (by Shiva 旧) - 没有CHAP安全 + 不防重放攻击(通信使用相同凭证)
            - 挑战握手验证协议CHAP (复杂)
              - 三次握手：用户名明文+MD5值
              - 0. S生成随机值 - 生成MD5值=H(随机值, 密码)
              - 1. S发Challenge报文[会话ID|随机值|用户名]
              - 2. C生成MD5值=H(随机值, 密码) - 发Response[MD5值|用户名]
              - 3. S比较MD5值 - 相同=响应Success=认证通过
            - 微软MS-CHAP：MS版 (v2 2000 旧)
              - v1演化：CHAP两端密码明文 》两端密码加密=H(pwd)
              - v2演化：单向验证终端 》双向验证 - Hash未加盐+DES+用户名明文 》不安全!
              - v2工作模式
                - MSCHAPv2：PC-NAS(发挑战值)-AAA(匹配哈希值)
                - EAP-MSCHAPv2：PC-NAS-AAA(发挑战值+匹配哈希值)
          - 3.3 网络控制协议NCP
            - 获取IP地址/DNS Server地址 via IPCP/BCP协议
            - C/S互发Parameter-Request报文 - 互回Parameter-ACK报文 - 协商网络层参数：IP Address | 网关 | 掩码...
        - 4. PPP报文传输
  - IEEE 802.1x认证
    - 基于端口的网络访问控制(PNAC)：对接入交换机物理端口的终端使用EAPoL+AAA - 需客户端+WPA2 适用安全场景
    - Frames (帧)
      - Data frames
      - Control frames
      - Management frames(MGT)
        - beacons：AP每100ms发送传达信息，如SSID, 支持的数据速率, WPA 2/3, 信道... (信标帧)
        - authentication | deauthentication：如OSA, SKA, WPA2-EAP, WPA2-PSK...
          - 报文
            - EAPoverLAN帧：协议类型|版本| 类型 | Len | 载荷=EAP帧
              - 协议类型版本：协议802.1x | 版本2001/2010
              - 类型：00-Packet| 01-Start| 02-Logoff| 03-Key
            - EAP帧：Code|ID|Len | 类型 | 数据
              - Code：1-Request| 2-Response| 3-Success| 4-Failure
              - 类型：1-Identity询问 4-MD5 Challenge| 5-OTP| 6-GTC| 254-扩展类型...
        - association | disassociation：C端向AP请求连接，如C端MAC
        - probe request | response：向附近探测请求|响应
    - 可扩展认证框架EAP
      - 演化：PC与AAA使用不同协议(PPP-AP & RADIUS) 》NAS一旦支持EAP=无需定制直接中转、40+类型
      - 0. 终端请求EAPoL-START
      - 单向验证 (旧)
        - 1. NAS请求EAP-Request/Identity - 终端响应EAP-Response/Identity[用户名明文]
        - PAP (1...)
          - 2. NAS请求EAP-Request/PAP - 终端响应EAP-Response/PAP[密码明文]
        - CHAP (1996)
          - 2. NAS请求EAP-Request/Challenge - 终端响应EAP-Response/MD5-Challenge[MD5值]
        - EAP-MD5 (1998)
          - 2.1 NAS请求RADIUS-Access Request - 认证服务器AS请求RADIUS-Access Challenge
          - 2.2 同CHAP
        - 3. NAS请求RADIUS-Access Request[用户名明文+密码密文/MD5值] - AS响应ACCEPT - NAS返回EAP-SUCCESS
      - EAP-TLS (1999)
        - 演化：仅认证终端、MD5弱哈希 》+PKI证书双向认证
        - 1. NAS请求Identity request - 终端响应Identity response[用户名明文] - NAS请求RADIUS-Access Request
        - 2. 服务器证书+终端证书双向PKI认证
        - 3. AS响应ACCEPT - NAS返回EAP-SUCCESS
      - EAP-TTLS (by FS+...)
        - 演化：EAP-TLS使用PKI太耗时 》TLS隧道(服务器证书X.509) + 内部认证协议
        - 1. 同EAP-TLS
        - 2.1 AS响应EAP-Request/TTLS-Start - 终端|AS进行TLS握手 - 认证 服务器 + 建立TLS隧道 via 非对称K
        - 2.2 终端请求EAP-Request/Identity - AS挑战EAP-Request/Challenge - 终端Response - AS验证Success - 认证 终端 via 内部认证协议
        - 3. TLS隧道关闭(生存时间毫秒) - AS响应ACCEPT - NAS返回EAP-SUCCESS
      - 受保护PEAP (by MS+Ci...)
        - 演化：轻量级EAP-TTLS = 内部认证协议仅支持EAP inside EAP
        - 类型
          - PEAPv0 (EAP-MSCHAPv2 | EAP-TLS)：MS版、OS内置
          - PEAPv1 (EAP-GTC)：Cisco版 (2004) - 双因素：通用令牌卡GTC(如RSA SecurID令牌)+用户名密码
      - 轻量LEAP：用于WPA (2000 旧 Cisco专用)
        - 演化：单向认证+静态密码 》双向认证+会话动态K - Asleap攻击
        - 1. 同单向认证
        - 2. NAS请求RADIUS Access Request - AS请求LEAPServer Challenge - 终端响应LEAPServer Response - AS响应ACCEPT - NAS返回EAP-SUCCESS - MS-CHAPv2 认证终端 H(pwd)
        - 3. 终端请求LEAPClient Challenge -AS响应LEAPClient Response - NAS返回LEAPClient ChallengeResponse - MS-CHAPv2 认证服务器
      - EAP-FAST安全隧道灵活验证 (2007 by Cisco)
        - 演化：LEAP使用MS-CHAPv2被破解 》+安全隧道(PAC) - PAC受保护认证凭证 = 终端与AS之间的PSK
        - 00. AS生成PAC - DH交换/手动分配至终端 - DH交换匿名>中间人攻击；手动分配>耗资源!
        - 0. 1. 同EAP-TLS
        - 2.1 AS请求EAP-Request/Start-FAST - 终端响应Client PAC - AS验证PAC - 建立TLS隧道 via 对称K!
        - 2.2 AS请求GTC-Request/Identity - 终端响应GTC-Response/Identity[用户名] - AS验证GTC凭证 - EAP-GTC内部认证
        - 3. 同EAP-TTLS
      - EAP-POTP：单向/双向多因素身份验证 by +RSA token的OTP (2007)
      - 移动网络 (2006)
        - EAP-SIM：适用全球移动通信系统GSM网络、单向认证用户终端UE - 每个终端持有SIM卡绑定帐号和服务级别
        - EAP-AKA：适用3/5G通用移动通信系统UMTS网络、双向认证
      - EAP-PSK (2007)
        - 适用WLAN、终端与AS预存PSK+AES128、无DH交换+PFS会话密钥+身份隐藏
        - 预共享密钥PSK
          - => 认证AK：静态、终端|AS的双向认证
          - => 密钥衍生密钥KDK：静态 +AES=会话密钥
            - => 临时EAP密钥TEK：用于AES128加密、建立隧道
            - => 主会话密钥MSK：终端|AS分别生成 - AS发送NAS
            - => 扩展EMSK：预留
          - 劣：太分散管理
      - EAP-IKE2 (2007) - 双向认证、支持证书/密码/共享密钥
      - EAP-GSS：基于通用安全服务GSS、使用Kerberos
    - *协议
      - 802.1 AR：为设备提供唯一ID
      - 802.1 AE：MACSec - L2逐跳加密+完整性+源验证
      - 802.1 AF：会话密钥协商的函数
  - WLAN认证
    - WPA-PSK - 所有用户使用同一个连网密码 - 无需客户端 适用家庭无线
    - WPA-802.1x - 动态PMK + 不同用户可用不同连网密码 via AS - 适用企业
- WLAN接入
  - 拓扑：终端STA - 接入点AP - 交换机 - 接入控制设备AC
  - 流程
    - 1. 服务发现
      - 被动扫描：AP定时发信标帧Beacon [SSID | 接入认证算法 | 密钥]
      - 主动扫描：STA发Probe Request - AP回Probe Response [SSID | 接入认证算法 | 密钥]
    - 2. 链路认证 (STA接入...)
      - 开放系统认证OSA - STA发Auth Request [MAC|Auth算法OS] - AP回Auth Response [Successful] - 即不认证
      - 共享密钥认证SKA
        - 1) STA发Auth Request [MAC|Auth算法SK] - AP回Auth Response [Challenge明文] - 不安全：明文+密文+静态WEP密钥》推算密钥
        - 2) STA用WEP密钥加密Challenge明文 - 发Auth Request [WEP Data(密文+初始向量IV明文+完整性校验值ICV明文)]
        - 3) AP解密+匹配 - 回Auth Response [Successful]
    - 3. 终端关联 - STA发Association Request [MAC|SSID] - AP回Association Response [Successful]
    - 4. 接入认证 (STA接入...) - via MAC | Portal | PSK | 802.1x [生成PMK]
    - 5. 密钥协商
      - 对话时密钥PTK
        - PMK = 会话密钥-802.1x / PSK-手动配置
        - 512位、用以加密单播报文、=SHA1-H(PMK,ANonce,SNonce,AP'MAC,STA'MAC)
        - 组成
          - EAPoL Key Integrity Key(KCK)：检验MIC
          - EAPoL Key Encryption Key(KEK)：加密新GTK
          - TKIP：128位 Temporal Encryption Key(TEK) | 128位 MIC Key - CCMP：128位 Temporal Key(TK)
      - 组临时密钥GTK
        - GMK：AP生成、定期/关联结束后更改 via 组播密钥更新
        - 256位、用以加密组播/广播报文、=H(GMK,...)
      - 单播密钥协商-四次握手
        - 0. 每个节点(STA,AP)预设PMK - AP生成随机值ANonce - Nonce：保证报文实时性
        - 1. AP发EAPOL-KEY帧[ANonce] - STA生成SNonce+计算PTK - 使用KCK加密MIC Key
        - 2. STA发EAPOL-KEY帧[SNonce | MIC密文] - AP计算PTK,(GTK) - 使用KCK提取MIC Key
        - 3. AP发EAPOL-KEY帧 [请安装密钥|MIC密文 |(GTK)] - STA安装PTK
        - 4. STA发EAPOL-KEY帧[空数据=我已安装密钥|MIC密文] - AP安装PTK
      - 组播密钥更新
        - 0. AP生成新GMK - 计算新GTK+用KEK加密
        - 1. AP发EAPOL-KEY帧[MIC密 | GTK密文] - STA解密+安装新GTK
        - 2. STA发EAPOL-KEY帧[MIC密] - AP验证MIC+安装新GTK
    - 6. 数据加密
      - 有线等效私密性WEP
        - 生成初始向量IV - 生成密钥序列=RC4-E(24位IV, 40/104位密钥) - 计算数据的ICV - XOR(数据+ICV, 序列)=数据密文
        - 劣：IV-静态|明文发送|长度短|重复使用 > 对称密钥-静态|长度短、ICV-CRC函数=无法发现篡改 - AirSnort/WEPCrack破解
      - 临时密钥完整性协议TKIP
        - 演化：IV改48位动态、+MIC(Data+MAC)、CTR模式加密(TEK,MIC Key,KCK) - coWPAtty/基于GPU的暴力破解工具
        - 数据帧：IV | 扩展EIV | Data | MIC|ICV
      - 计数器模式密码块链接消息认证协议CCMP
        - 演化：改用AES、CTR模式加密TK + CBC模式加密KCK、-冗余ICV
        - 数据帧：IV | EIV | Data | MIC
        - 密钥重新安装KRACK攻击：四次握手结束 > PTK|TK清零 - 黑客重传#3 > STA重安装PTK > 此时PTK=0 (2017) - 已有补丁
  - 安全标准
    - 有线等效私密性WEP (1999 旧) - 链路认证(SKA) - 数据加密
    - WiFi保护访问(WPA) (2003 旧) - 演化：急于改进WEP、数据加密-TKIP - TKIP依然RC4=可仅升级WEP设备固件和驱动
    - IEEE802.11i子集：WPA2 (2004) - 改进：接入认证+802.1x=PMK不再静态、数据加密-AES-CCMP、引入新认证元素
      - CCMP改用AES=必须购置新设备
      - 认证元素：PER-PSK(<密码暴破攻击)、ENT-802.1x
    - 最新实现
      - WPA/WPA2：已无差别 - 均支持：链路认证(OSA) - 接入认证(PSK/802.1x) - 数据加密(TKIP/CCMP)
      - WPA3：前提"设备支持新协议" (2018)
        - WPA3-PERSONAL (WiFi5设备支持)
          - 改进：128位AES-CCMP加密、SAE接入认证 取代WPA2-PSK + 强制PMF
            - *对等实体同步验证SAE：基于蜻蜓握手(零知识证明) - 双方各自生成PMK - commit|confirm：提交生成素材|验证计算结果
            - *管理帧保护PMF：保护Action, Disassociate等单播/组播的管理帧 (IEEE 802.11w-2009)
          - 模式
            - WPA3-SAE模式
            - WPA3-SAE过渡模式：允许WPA2和WPA3同时存在
          - 优：无需用户名、抗字典攻击、安全
        - WPA3-ENTERPRISE (企业用) - 改进：：192位...、数据加密-GCMP256(伽罗瓦计数器模式协议)
    - 中国：WAPI
      - 演化：解决WEP安全问题 - 中国研发
      - WAI：用户和WLAN设备双向身份验证
      - WPI：数据加密
  - 安全
    - WiFi路由器
      - 快速安全设置QSS/WPS功能 for 快速联网
        - *WiFi保护安装WPS
          - 一个安全标准；大量终端入网 - 一键添加 > 简化工作
          - 流程：按WPS按钮(+PIN) - 2分钟后按终端的WPS按钮 - 自动互联
        - 攻击：PIN仅8位数字 》暴力破解 - 防：禁用WPS - 每次固件升级后核实
      - 公网地址默认开启telnet - 攻击：进入路由器-执行wlctl show命令-获取无线密码
    - 攻击
      - 战争驾驶：使用手持探测器/无线功能移动设备/OS自带功能/无线扫描仪 定位WIFI信号 - 发现SSID(无论是否隐藏) - 使用无线破解器解密WiFi
      - Rogue AP (流氓/伪)
        - 定义：员工/黑客部署未经授权的AP - 可被利用进入企业内网
        - 类型
          - 针对现存无线客户端 by 克隆AP(SSID,MAC,信道) - 设备自动连入
          - 吸引新的无线客户端 by 相似SSID (MAC和信道可不同) - 社会工程欺骗用户连入
        - 防
          - 部署WIDS
          - 无线扫描工具：发现伪AP+测试AP安全性，如Aircrack-ng
          - 用户通过VPN连入无线
      - 邪恶双胞胎：基于用户请求自动克隆AP
        - 原因：客户端不对AP作身份验证
        - 流程
          - 1. 用户设备成功连接AP - 设备自动保存配置文件
          - 2. 下次 当设备启用无线适配器 + 设备进入区域时 - 将自动发送连接请求 (含SSID, MAC)
          - 3. 黑客发现请求 - 伪装成AP - 提供连接(含明文SSID) - 设备接受 》MitM成功
        - 防：当设备连入不在附近的网络=可能被攻击、删除旧的配置文件、通过VPN连入无线
      - WiFi解除关联 (Disassociati...)
        - 正常：设备与WAP1连接 - 进入相同ESSID区域时 - 与WAP2尝试连接 = 现有连接断开
        - 黑客
          - 对于隐藏的SSID，伪装AP向设备发送含MAC的disass包 - 连接断开 - 黑客发送reass请求(含明文SSID) 》设备与黑客连接
          - 不断向设备发送disass包 - 连接断开+设备无法reass 》DoS
          - 黑客发送disass包 - 连接断开 - 黑客冒充设备与AP连接 》MitM成功
        - 相似 - Deauthentication (解除身份验证)
          - 正常：设备尝试连WAP - 身份验证失败 - 设备收到deauth包
          - 黑客：设备正在连接 - 黑客向设备发送包 - 被视作验证失败 - 连接断开
        - 防：部署WIDS
      - WiFi干扰：干扰无线信号 by 降低信噪比 (Jamming) - 防：调整AP物理位置、检查使用相同频率的设备-更改频率/信道
      - IV滥用：IV太短/明文等 = 易被破解，如WEP
      - 重放：绕过验证 重新建立会话 - 访问目标系统
        - 如：伪装成设备与AP通信、DoS
        - 防：更新AP固件、WIDS、OTP、时间戳/有效期、挑战响应机制、顺序会话标识
      - 战争粉化：黑客涂鸦 by 圆圈标记封闭/开放网络 - 告知他人，当今WiFi无处不在 》再没必要
    - 防
      - 更新固件
      - 管理密码强度
      - 加强身份认证：WPA2>WPA/WEP>无 / 使用AAA
      - 关闭SSID广播 /隐藏SSID /改变默认SSID(唯一性)
      - 修改无线MAC地址 - 隐藏OUI/设备品牌型号
      - MAC过滤器 / 静态IP / 关闭DHCP：适用小型+静态环境 - 但 帧头仍明文=被嗅探
      - 防火墙隔离无线和有线 + 部署WIDS监控从无线到有线的流量
      - 通过VPN加密无线终端与AP间的通信 - *数据加密WPA2+IPSec VPN > 降低吞吐量80%
      - 针对不同用户类型部署独立VLAN

Presented with xmind